Data Governance, (Compliance) and Ethics



WEEK 06: PRIVACY AND DATA PROTECTION (PART 3)

Jaswinder.singh@ncirl.ie

Overview of course content

1. Data Governance and Management (Weeks 1-3)
2. Privacy and Data Protection (Weeks 4-6)
3. Ethical Issues Pertaining to Data (Weeks 7-9)
4. Fairness, Accountability, and Transparency of Algorithmic Systems (Weeks 10-12)

Recap

Last week, we looked at **Privacy and Data Protection (Part 2)**

- ✓ Common law protection
- ✓ Data Protection Regulation Scope
- ✓ Data Controller & Data Processor
- ✓ Data Protection Principles
- ✓ Data Subject Rights
- ✓ Legitimate bases for processing
- ✓ …

An Coimisiún um Chosaint Sonraí
Data Protection Commission

When Does the GDPR Not Apply?







1. Lawfulness, Fairness, and Transparency
2. Purpose limitation
3. Data minimization
4. Accuracy
5. Storage limitation
6. Integrity and Confidentiality
7. Accountability



Agenda Today

3. Privacy and Data Protection (I, II, III)

- Data Protection in practice including international transfers, surveillance, cloud computing, and auditing. Current reform of the area.

Data Transfer to Third Countries



Transfers of Personal Data

What happens when data transfers are required for international commerce or co-operation?

- EU law requires that this is done in a way that is "essentially equivalent" to those required under EU law (EDPB, 2000)
- A third country refers to any country outside the European Economic Area (the "EEA").
- Essentially EU provides for a tiered approach in providing such protections.



GDPR Ch 5 Article 44
General principle for transfers

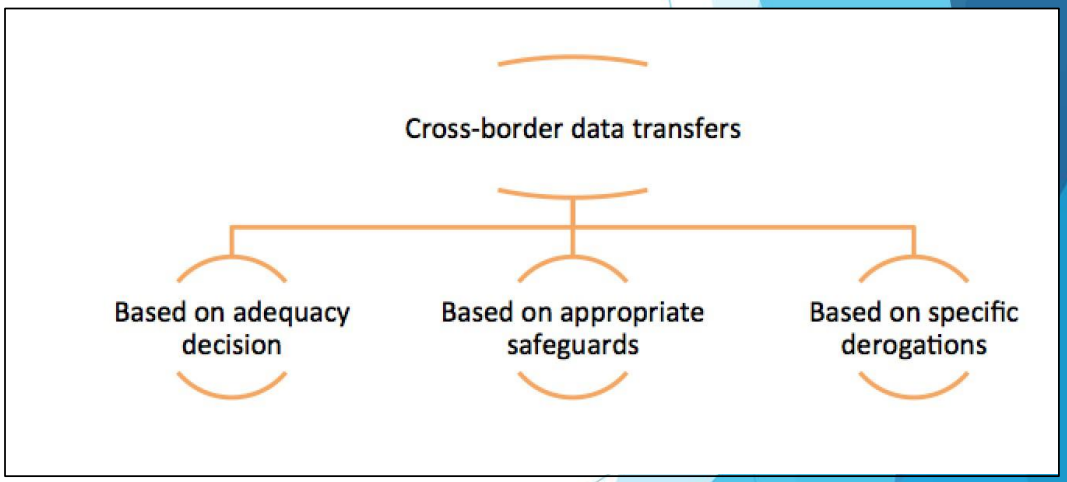
Art. 44 GDPR
General principle for transfers

[1] Any transfer of personal data which are undergoing processing or are intended for processing after transfer to a third country or to an international organisation shall take place only if, subject to the other provisions of this Regulation, the conditions laid down in this Chapter are complied with by the controller and processor, including for onward transfers of personal data from the third country or an international organisation to another third country or to another international organisation. [2] All provisions in this Chapter shall be applied in order to ensure that the level of protection of natural persons guaranteed by this Regulation is not undermined.

Transfers of Personal Data



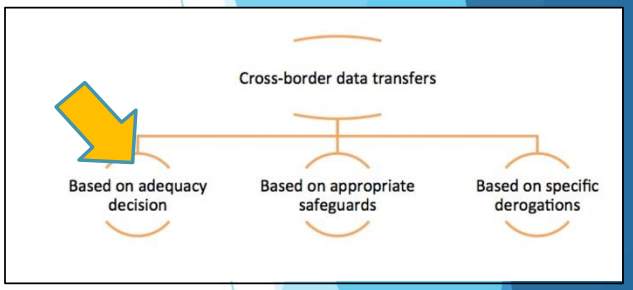
1. Transfers on the basis of an **adequacy decision** (Art. 45 GDPR)
2. Transfers subject to **appropriate safeguards** (Art. 46 GDPR)
3. **Derogations** for specific situations (Art. 49 GDPR)



https://www.dataprotection.ie/en/organisations/international-transfers/transfers-personal-data-third-countries-or-international-organisations

Transfers Based On Adequacy Decision (Art. 45 GDPR)

- A transfer of personal data to a third country or an international organisation may take place where the Commission has decided that the third country, a territory or one or more specified sectors within that third country, or the international organisation in question ensures an adequate level of protection. Such a transfer shall not require any specific authorisation.



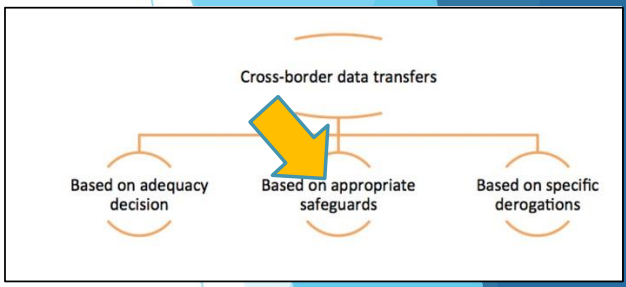
⇒ **Effect of adequacy decision: the transfer is the same as if was carried out within the EU (intra-EU transmissions of data)**

Adequate level of protection? After evaluating number of factors such as the laws, respect for human rights and freedoms, national security, data protection rules, the existence of a data protection authority and binding commitments entered into by the country in respect of data protection

The European Commission has so far recognised Andorra, Argentina, Canada (commercial organisations), Faroe Islands, Guernsey, Israel, Isle of Man, Japan, Jersey, New Zealand, Republic of Korea, Switzerland , the United Kingdom under the GDPR and the Law Enforcement Directive, and Uruguay as providing adequate protection.

https://ec.europa.eu/info/law/law-topic/data-protection/international-dimension-data-protection/adequacy-decisions_en

Transfers Subject To Appropriate Safeguards (Art. 46 GDPR)

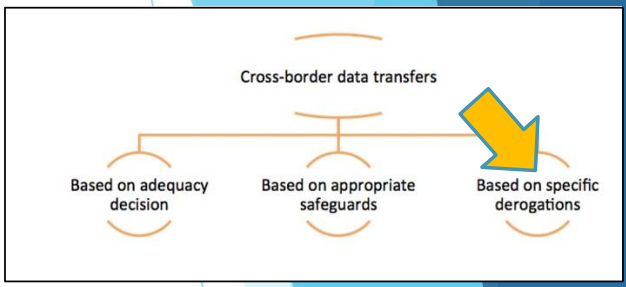


- In the absence of an adequacy determination, personal data only transferred subject to “appropriate legally enforceable safeguards”
- These may include:

1. **Standard data protection clauses** contain contractual obligations on the Data Exporter and the Data Importer, and rights for the individuals whose personal data is transferred. Known as “standard contractual clauses **(SCC)**. There are SCC between controller-controller and controller-processor.
2. **Binding Corporate Rules (BCRs)** — a legally binding internal code of conduct operating within a multinational group (approved by DPA, contain enforceable data subject rights, BCRs for controllers and processors) – further provisions on the use of BCRs are set out in GDPR Art. 47
3. an **approved code of conduct** pursuant to Article 40 together with binding and enforceable commitments of the controller or processor in the third country to apply the appropriate safeguards, including as regards data subjects’ rights;
4. an **approved certification mechanism** pursuant to Article 42 together with binding and enforceable commitments of the controller or processor in the third country to apply the appropriate safeguards, including as regards data subjects’ rights.

Approved BCRs: https://edpb.europa.eu/our-work-tools/accountability-tools/bcr_en

Transfers based on Specific Derogations (Art.49 GDPR)



- **Derogations are exemptions** from the general principle that personal data may only be transferred to a third country if an adequate level of protection is provided for in that third country

- In the absence of an adequacy decision or appropriate safeguards, transfers shall take place only in following circumstances:

a) **Consent** — based on individual's informed consent on specific cross-border data transfer.

b) **Contract** — based on a contract between the individual and the organization.

c) **Contract** - concluded in the interest of the data subject

d) **Public interest** — important reasons of public interest.

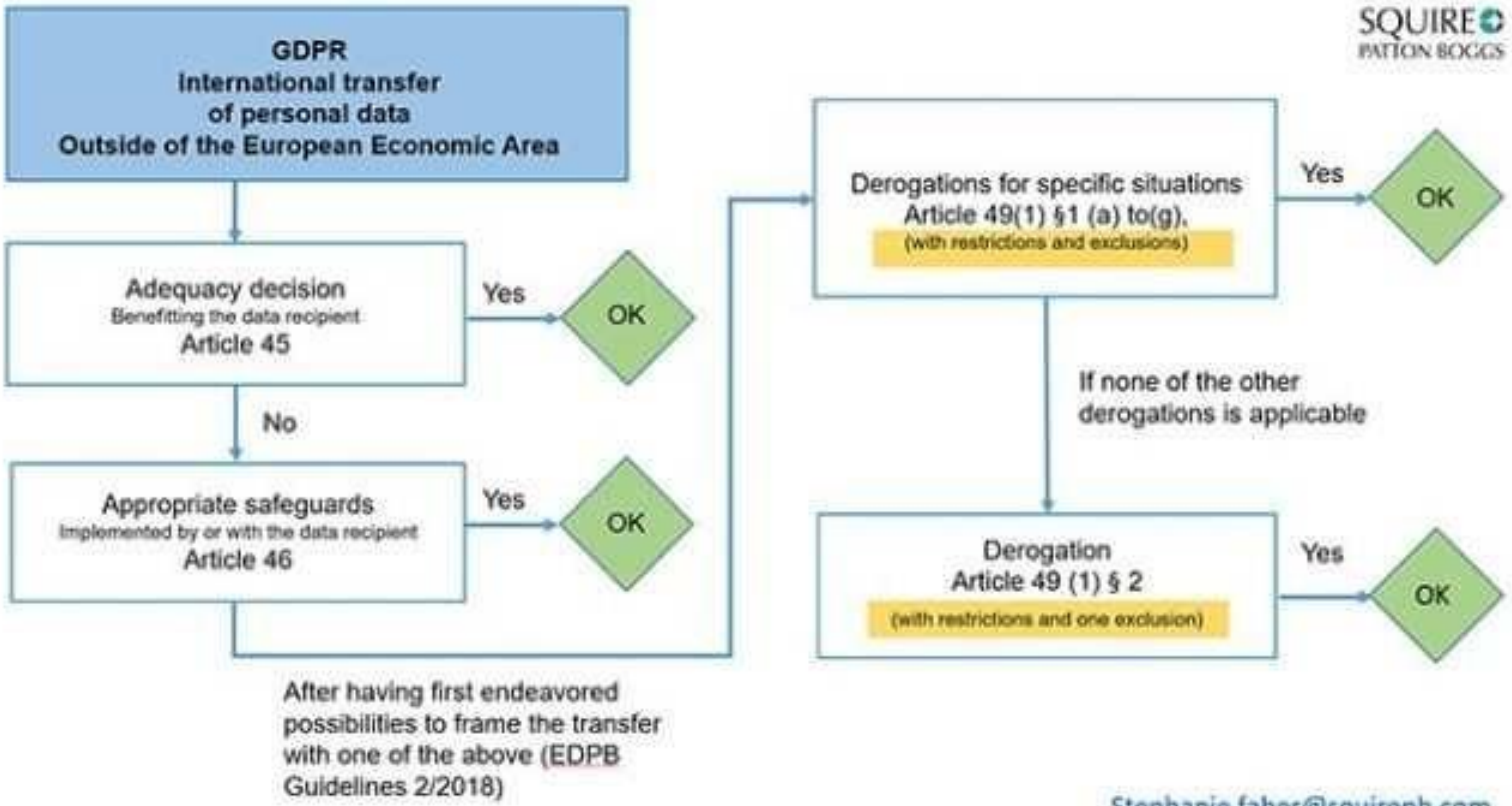
e) **Legal claims** — to exercise or defence of legal claims.

f) **Vital interests** — vital interests of the individual or other persons, where the individual is incapable of giving consent.

g) **According to EU law** — intended to provide information to the public on legitimate interest.

https://edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_2_2018_derogations_en.pdf

Data Protection in practice: international transfers (summary graphic)



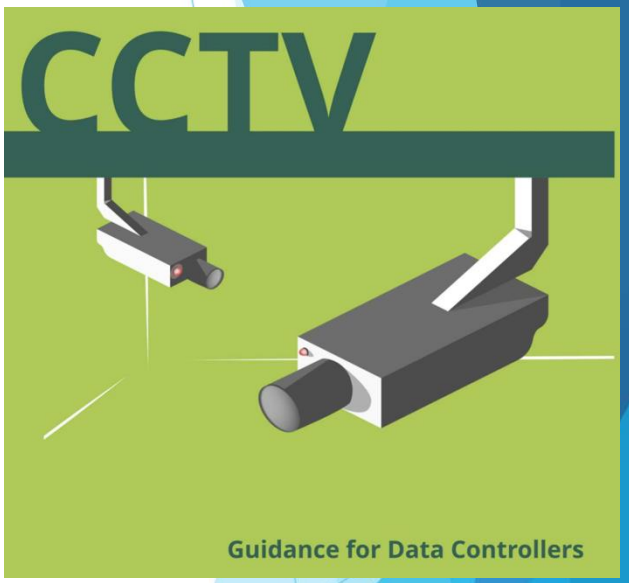
Stephanie.faber@squirepb.com

Data Protection In Practice Including Surveillance



Surveillance

- CCTV systems must be used only where there is a **legitimate use** that is documented. **Data controllers must be aware of DP implications both ethical and legal**
- The **legitimate uses** could be for example in securing premises, supporting workplace safety management, and aiding in the prevention and detection of crime.
- Data controllers should be aware that **footage or images containing identifiable individuals captured by CCTV systems are personal data** for the purposes of data protection law.
- **Even** where processes are used to **obscure or de-identify** individuals from CCTV footage, the footage or images are still considered personal data **if it is possible to re-identify** the individuals (analogous to pseudo-anonymization)



https://www.dataprotection.ie/

CCTV Checklist

- Purpose
- Lawfulness
- Necessity
- Proportionality
- Security
- Retention
- Transparency



https://www.dataprotection.ie/sites/default/files/uploads/2019-05/CCTV%20guidance%20data%20controllers_0.pdf

CCTV Checklist

- Purpose
- Lawfulness
- Necessity
- Proportionality
- Security
- Retention
- Transparency

- Do you have a clearly defined purpose for installing CCTV?
- What are you trying to observe taking place?
- …

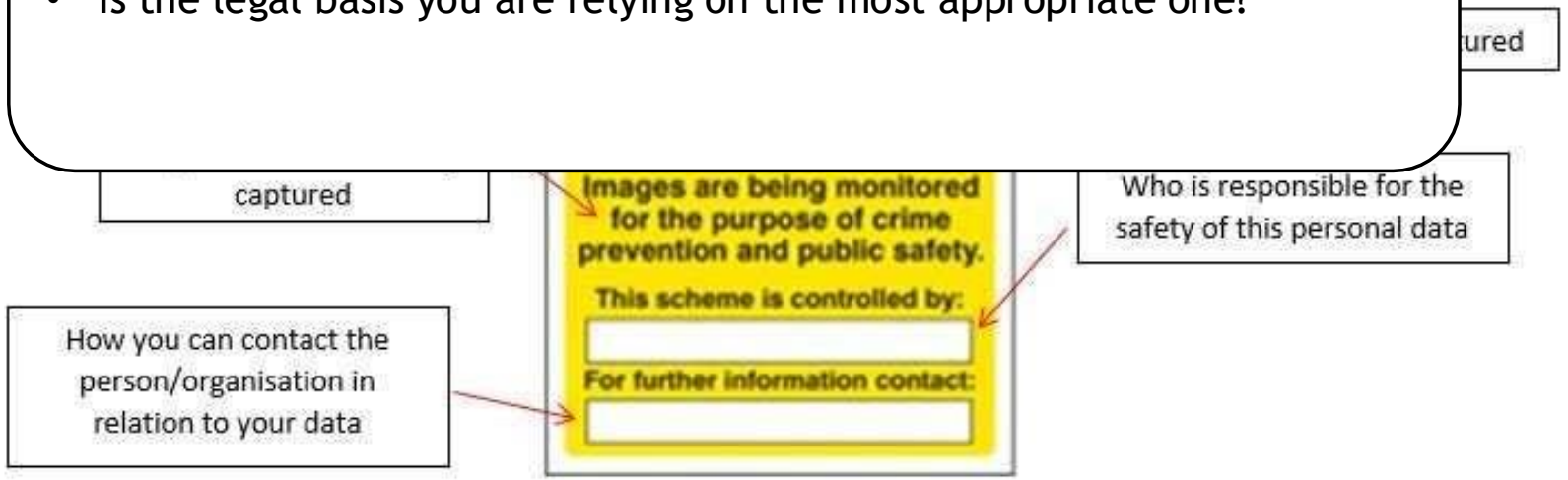


https://www.dataprotection.ie/sites/default/files/uploads/2019-05/CCTV%20guidance%20data%20controllers_0.pdf

CCTV Checklist

- Purpose
- Lawfulness
- Necessity
- Proportionality
- Security
- Retention
- Transparency

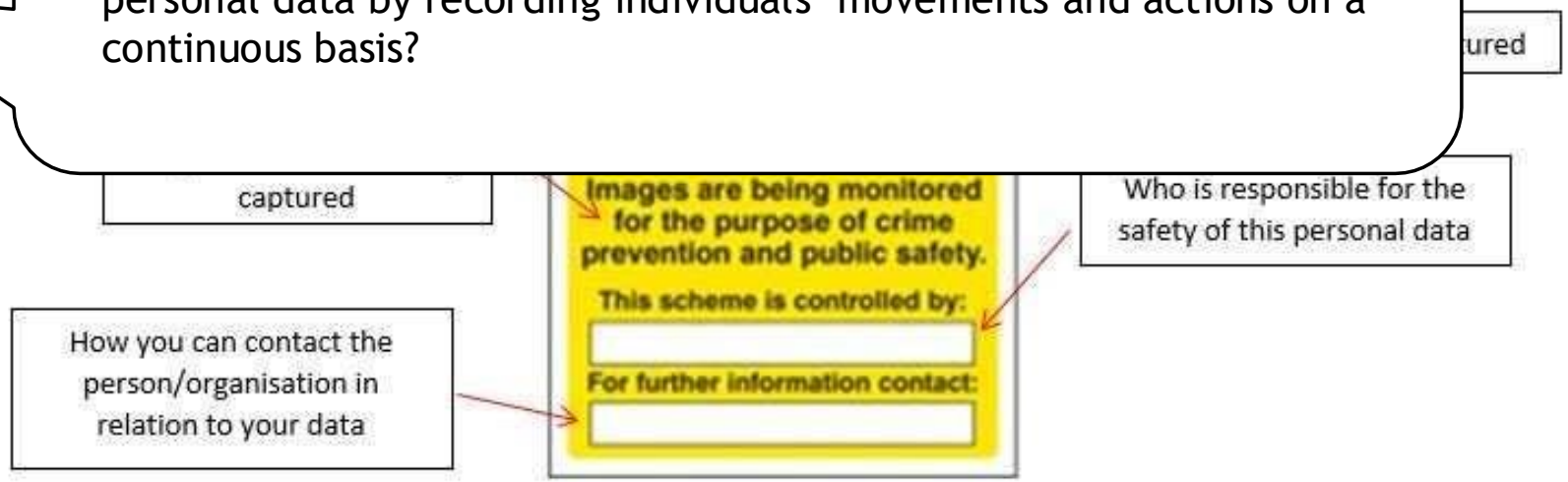
- What is the legal basis for your use of CCTV?
- Is the legal basis you are relying on the most appropriate one?



CCTV Checklist

- Purpose
- Lawfulness
- Necessity
- Proportionality
- Security
- Retention
- Transparency

- Can you demonstrate that CCTV is necessary to achieve your goal?
- Have you considered other solutions that do not collect individuals' personal data by recording individuals' movements and actions on a continuous basis?



CCTV Checklist

- Purpose
- Lawfulness
- Necessity
- Proportionality
- Security
- Retention
- Transparency

Example 1: The owner of a convenience shop intends to install a CCTV system to aid in the prevention and detection of thefts and to protect the security of the premises at night. The shop, along with others in the area, has been subject to robberies and shoplifting in the recent past. The shopkeeper identifies the prevention and detection of crime, and the safety of staff members as the purposes for installing CCTV.

- The necessity of using CCTV is justified by the shopkeeper based on the ongoing threat of crime and the lack of viable alternative solutions.
- Internal camera to cover publicly accessible area of the shop where shoplifting has taken place in the past, and the till area where staff are at risk of robbery.
- External camera will be focused on the door of the premises.

CCTV Checklist

- Purpose
- Lawfulness
- Necessity
- Proportionality
- Security
- Retention
- Transparency

If your CCTV system is to be used for purposes other than security,

- are you able to demonstrate that those other uses are proportionate? *E.g., staff monitoring in the workplace is highly intrusive*
- Will your CCTV recording be measured and reasonable in its impact on the people you record?
- Will you be recording customers, staff members, the public?
- Can you justify your use of CCTV in comparison to the effect it will have on other people?
- Are you able to demonstrate that the serious step involved in installing a CCTV system that collects personal data on a continuous basis is justified?
- You may need to carry out a Data Protection Impact Assessment to adequately make these assessments.

CCTV Checklist

- Purpose
- Lawfulness
- Necessity
- Proportionality
- Security
- Retention
- Transparency



- What measures will you put in place to ensure that CCTV recordings are safe and secure, both technically and organisationally?
- Who will have access to CCTV recordings in your organisation and how will this be managed and recorded?

CCTV Checklist

- Purpose
- Lawfulness
- Necessity
- Proportionality
- Security
- Retention
- Transparency



CCTV Checklist

- Purpose
- Lawfulness
- Necessity
- Proportionality
- Security
- Retention
- Transparency



- How will you inform people that you are recording their images and provide them with other information required under transparency obligations?
- Have you considered how they can contact you for more information, or to request a copy of a recording?

Recommended Data Protection Policy

- Best practice is to set out your position on the issues surrounding the use of CCTV in the form of **a CCTV Data Protection Policy**
- Any policies should also be reviewed on a regular basis to ensure that they are being applied as intended and are adapted in light of any relevant changes in circumstances
- The situation that originally necessitated the installation of CCTV may have changed, requiring a reassessment of the necessity and extent of its ongoing use.

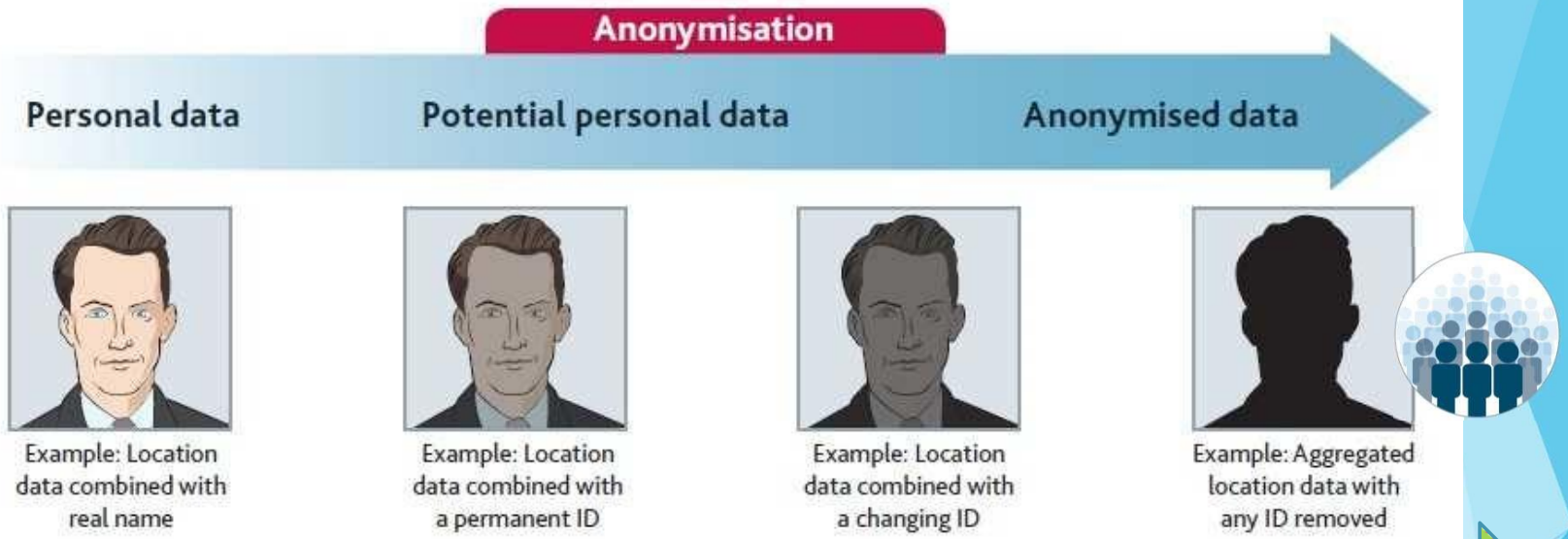


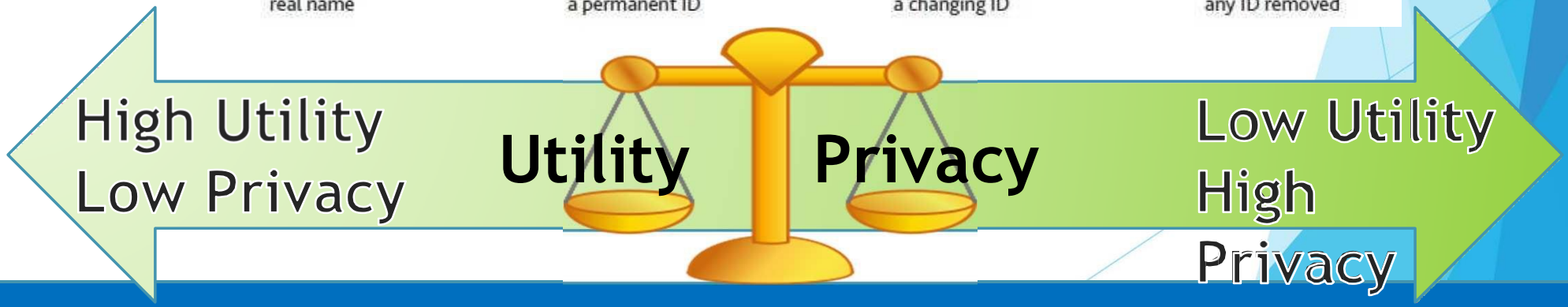
10. CCTV on the NCI Campus

10.1 NCI has closed circuit television cameras ("**CCTV**") located throughout its premises covering buildings, internal spaces, car parks, roads, pathways and grounds. NCI's CCTV system is implemented in a proportionate manner as necessary to protect NCI property against theft or pilferage and for the security of staff, students and visitors to the NCI premises to protect their vital interests.

10.2 Whilst CCTV footage is monitored by NCI security staff, and other authorised personnel access to recorded footage is strictly limited to authorised personnel. Footage is retained for 30 days, except where incidents or accidents have been identified in which case such footage is retained specifically in the context of an investigation of that issue. CCTV footage may be used in the context of disciplinary proceedings involving NCI staff or students (to protect the vital interests of NCI, staff, students and affected individuals). CCTV footage is not disclosed to third parties except where disclosure is required by law (such as for the purpose of preventing, detecting or investigating alleged offences) and in such instances disclosure is based on a valid request. Signage indicating that CCTV is in use is displayed prominently throughout the NCI premises. For information on CCTV operations at NCI please contact Mr Bertie Kelly by email at bkelly@ncirl.ie.

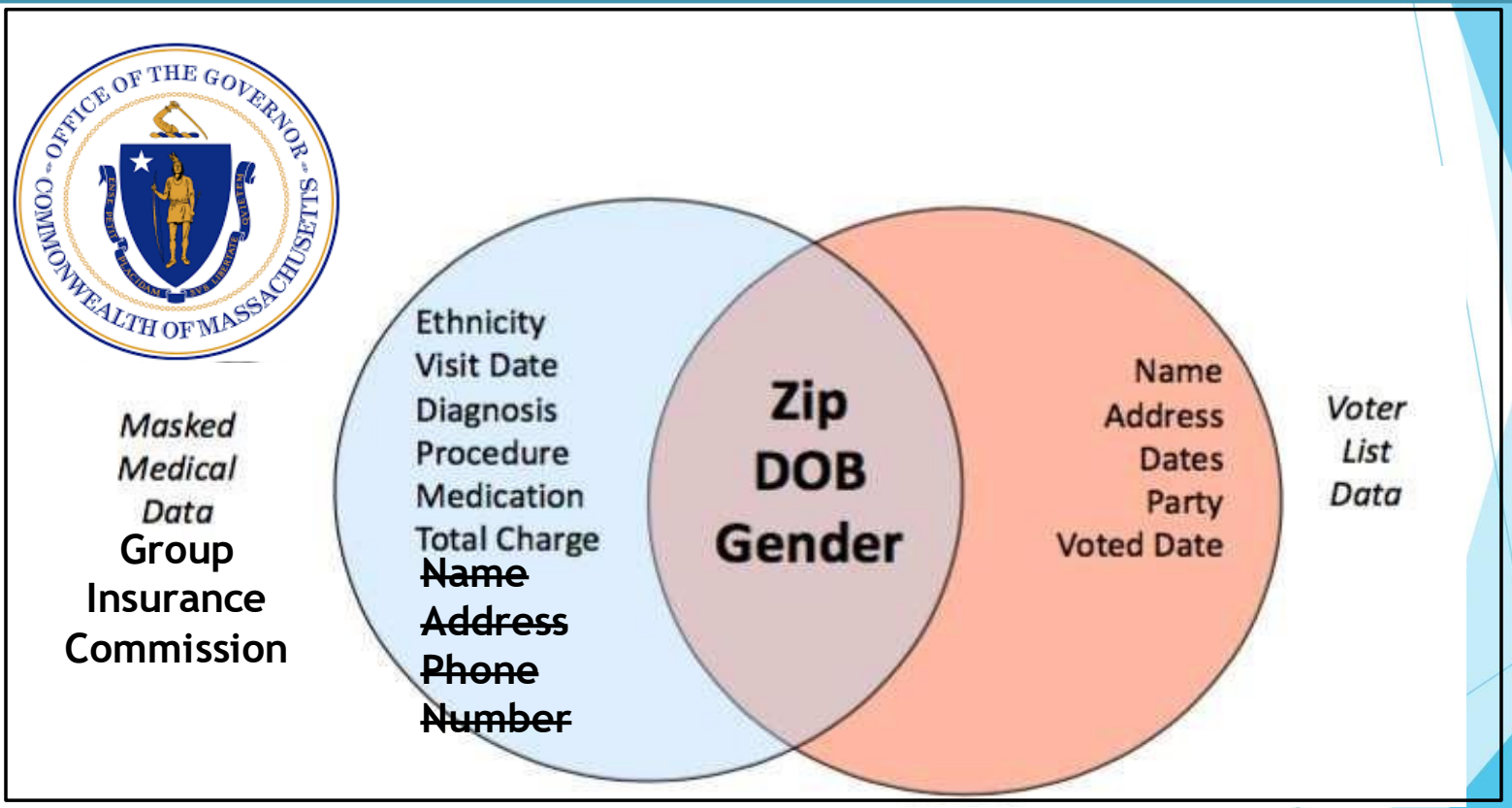
Data Anonymization





http://telematicsnews.info/2014/11/26/exclusive-opinion-piece-pinsent-masons-on-automotive-data-

Poor Anonymization



2002: Former Massachusetts governor's medical record re-identified

Poor Anonymization Cont.


Sport Culture Lifestyle More The Guardian

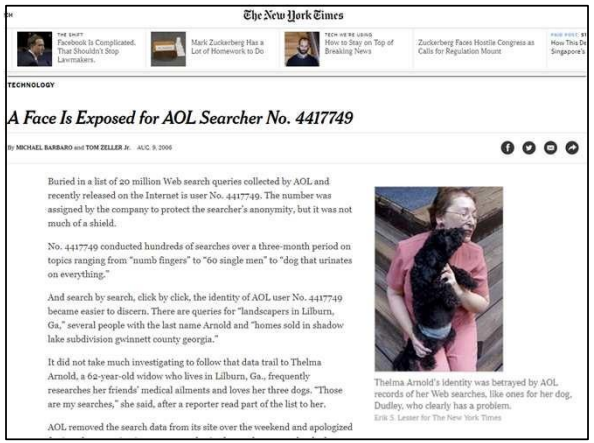
Teenager finds sperm donor dad on internet

Using nothing more than a swab of saliva and the internet, a 15-year-old boy has tracked down his anonymous sperm donor father, according to details released today.

By sending a swab taken from the inside of his cheek for genetic testing, the teenager was able to use genealogy websites to trace his father by looking for men with a matching Y-chromosome, which is passed down the male line.

The genetic detective work has major implications for men who have donated sperm under condition of anonymity and expect their identity to remain secret for ever. The news is expected to lead to a surge of other donor children

2005: teenager tracked down his anonymous sperm donor father


The New York Times

A Face Is Exposed for AOL Searcher No. 4417749

Buried in a list of 20 million Web search queries collected by AOL and recently released on the Internet is user No. 4417749. The number was assigned by the company to protect the searcher's anonymity, but it was not much of a shield.

No. 4417749 conducted hundreds of searches over a three-month period on topics ranging from "numb fingers" to "60 single men" to "dog that urinates on everything."

And search by search, click by click, the identity of AOL user No. 4417749 became easier to discern. There are queries for "landscapers in Lilburn, Ga," several people with the last name Arnold and "homes sold in shadow lake subdivision gwinnett county georgia."

It did not take much investigating to follow that data trail to Thelma Arnold, a 62-year-old widow who lives in Lilburn, Ga., frequently researches her friends' medical ailments and loves her three dogs. "Those are my searches," she said, after a reporter read part of the list to her.

AOL removed the search data from its site over the weekend and apologized

Thelma Arnold's identity was betrayed by AOL records of her Web searches, like ones for her dog, Dudley, who clearly has a problem.

2006: Identity discovered: Thelma Arnold, a 62-years-old widow who lives in Lilburn, Georgia



2008: Subscribers identified


Science Home News Journals Topics Careers

SHARE NEWS & ANALYSIS GENETICS

Genealogy Databases Enable Naming of Anonymous DNA Donors

John Bohannon

See all authors and affiliations

Science 18 Jan 2013: Vol. 339, Issue 6117, pp. 262 DOI: 10.1126/science.339.6117.262

2013: identity of anonymous DNA donors revealed


Poorly anonymized logs reveal NYC cab drivers' detailed whereabouts

Botched attempt to scrub data reveals driver details for 173 million taxi trips.

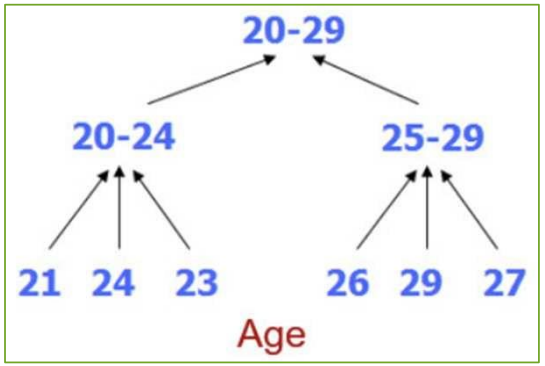
DAN GOODIN - 6/23/2014, 8:25 PM

2014: NYC cab drivers' detailed whereabouts revealed

Anonymization Techniques



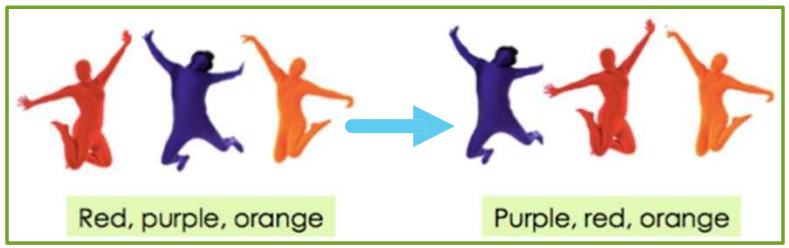
K-anonymity



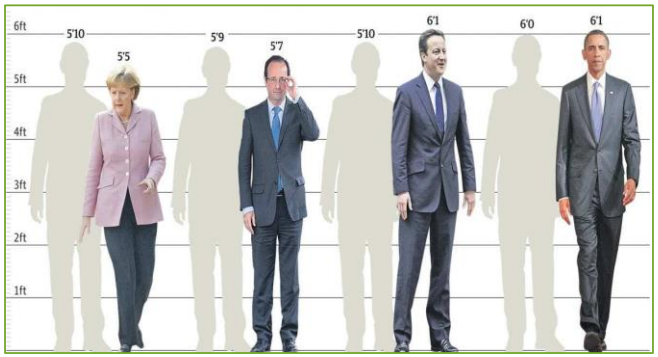
Generalization

73301 - 73***
32003 - 32***
99501 - 99***

Truncation



Permutation



Noise Addition



Pseudonymization

Auditing

- Data controllers need to regularly audit their holdings of personal data and the procedures they have in place to protect this data.

Questions they should ask include:

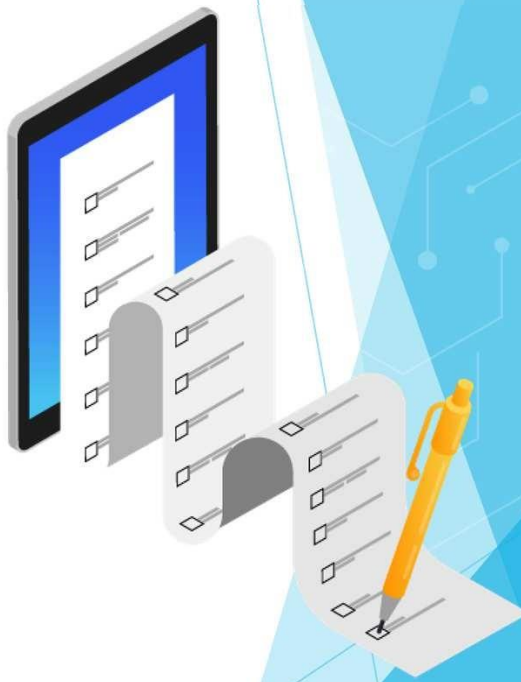
1. Do we know what types of personal data we hold:
   - electronically (including less obvious data such as CCTV images)?
   - on paper?
2. Are we satisfied with the level of security (access, editing, deletion) on our own systems and its documentation
3. If we outsource processing of personal data to a data processor (including a 'cloud computing' service provider), are we satisfied that their security procedures are adequate?



https://www.dataprotection.ie/en/organisations/know-your-obligations/data-security-guidance

Questions for auditing

4. Can we justify the collection of this information?
   - Why do we collect it?
   - What it is used for?
   - What are the risks and what kind are they?
   - How long do we hold it?
   - Who has access to it?
   - To whom do we disclose it?
   - Where will the data be stored?
   - Is it held securely?
   - How we dispose of the data?



Audit Example Questions

	Question	*Controller*	*Processor*
Personal data	Are you processing personal data?	✓	✓
Sensitive (special) personal data	Are you processing sensitive personal data?	✓	✓
Children's personal data	Is personal data of children collected and processed?	✓	✓
Lawful grounds for processing	Is there a lawful ground for processing the personal data for each processing operation?	✓	
	Is there a lawful ground for processing any sensitive personal data for each processing operation?	✓	
Consent	How is consent collected?	✓	
	How is this consent demonstrated?	✓	
	Can subjects withdraw their consent?	✓	

	Question	*Controller*	*Processor*
Purpose limitation	Is personal data only used for the purposes for which it was originally collected?	✓	
Data minimisation	Is the personal data limited to what is necessary for the purposes for which it is processed?	✓	
Accuracy	Are policies and training in place to ensure personal data are checked and where inaccurate are rectified without delay?	✓	
Storage limitation (retention)	Do privacy policies incorporate information on retention? Are there procedures in place for archiving and destruction of data?	✓	
Integrity and confidentiality	Are appropriate security measures used to protect the data?	✓	
Accountability	Can you demonstrate compliance with the data protection principles?	✓	

Current Issues/Reforms

1. ePrivacy Regulation
2. Provisions for Transfers to UK post-Brexit
3. Data Transfers to the US in the light of Schrems I and II cases

Proposal for e-Privacy Regulation



- A regulation on the respect for private life and the protection of personal data in electronic communications (First Draft January 2017).
- Will replace Directive 2002/58/EC (e-Privacy Directive)
- It introduces rules on cookies, direct marketing, and business-to-business communications
- 2022 is the year in which the ePrivacy Regulation is finalized and enters into force
  - ✓ **New players**: such as WhatsApp, Facebook Messenger and Skype to bring them on as traditional telecoms operators.
  - ✓ **Stronger rules**: all people and businesses in the EU will enjoy the same level of protection of their electronic communications through this directly applicable regulation.
  - ✓ **Communications content and metadata**: privacy is guaranteed for communications content and metadata.
  - ✓ **New business opportunities**: once consent is given for communications data to be processed, traditional telecoms operators will have more opportunities to provide additional services and to develop their businesses.
  - ✓ **Simpler rules on cookies**: the cookie provision, which has resulted in an overload of consent requests for internet users, will be streamlined.
  - ✓ **Protection against spam**: this proposal bans unsolicited electronic communications by email, SMS and automated calling machines.
  - ✓ **More effective enforcement**: the enforcement of the confidentiality rules in the Regulation will be the responsibility of data protection authorities, already in charge of the rules under the GDPR.

Current issues (BREXIT and data transfers to the UK)



- On June 28, 2021, the European Commission adopted two adequacy decisions for the UK: one under the GDPR and the other for the Law Enforcement Directive
- Personal data can now flow freely from the EU to the UK where it benefits from an essentially equivalent level of protection to that guaranteed under EU law
- The UK's data protection system continues to be based on the same rules that were applicable when the UK was a Member State of the EU. The UK has fully incorporated the principles, rights and obligations of the GDPR and the Law Enforcement Directive into its post-Brexit legal system.
- The adequacy decisions include a so-called ‘sunset clause', which strictly limits their duration

https://ec.europa.eu/commission/presscorner/detail/en/ip_21_3183

Current issues: Data Transfers to the US (in the light of Schrems I and II cases)

Safe Harbor: According to Schrems, Snowden's revelations demonstrated that the US did not adequately protect personal data from **NSA surveillance activities**.
The CJEU found that the Safe Harbor program did not adequately protect personal data from "interference" from the US government "founded on national security and public interest requirements."

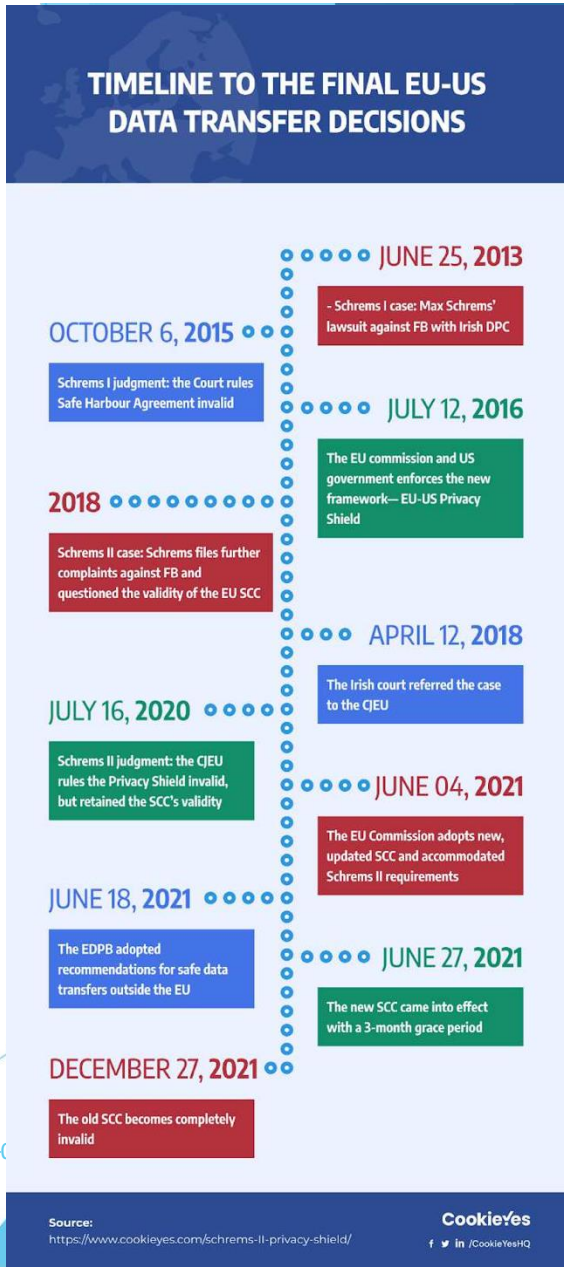

Facebook case may force European firms to change data storage practices

Changes may be required after European court advocate general accuses US intelligence services of 'mass, indiscriminate surveillance'

The Safe Harbor agreement allows the NSA to use the Prism surveillance system exposed by Edward Snowden to wade through billions of bits of personal data held by nine internet companies. Photograph: Dado Ruvic/REUTERS

Privacy Shield was invalidated partly due to its inability to protect EEA data subject's personal information from the **U.S. Government's surveillance** powers. Those powers are derived from national surveillance laws. **U.S. Surveillance Law**.





https://www.cookieyes.com/blog/schrems-ii-privacy-shield/

Current issues: Data Transfers to the US (in the light of Schrems I and II cases)

President Joe Biden has signed an executive order adopting new American intelligence gathering privacy safeguards, to protect citizens against data collection abuses.



In a press appearance with EU commission president Ursula von der Leyen, US President Joe Biden said the deal underscores a shared commitment to privacy, data protection and the rule of law. (AP)

Current issues: Data Transfers to the US (in the light of Schrems I and II cases)

Transatlantic Data Transfer Framework.

- A new agreement has been reached to patch cross-border data transfer after *Schrems II*.
- This new arrangement makes changes in the U.S. surveillance regime via executive order, and it revives the EU-US Privacy Shield.



Daniel Solove
Professor, GW Law School + CEO, TeachPrivacy + Organizer, Privacy+Security Forum

Current issues: Data Transfers to the US (in the light of Schrems I and II cases)

GDPR provides for the transfer of data of EU subjects to other jurisdictions provided either an "adequacy" decision by Commission or the inclusion of Standard Contractual Clauses (SSCs) between those making the data transfers.

The Commission had made with the US authorities (termed "Safe Harbour" and "Privacy Shield") that sought to provide an adequacy context in order to allow data transfers subject to the use of SSCs or other safeguards such as Binding Corporate Rules ("BCRs") .

Both "Schrems I and II" judgements by the CJEU reviewed data protection legislation to transfers to US from the EU in the light of the EU-US "Safe Harbour" agreement:

- **The Schrems I decision** (2015) by the CJEU had **invalidated** an adequacy decision underlying the **US-EU Safe Harbour arrangement** on the basis that it **did not apply an adequate level of protection to EU data subjects**.
- In **the Schrems II judgment**, the CJEU considered that **U.S. domestic law** (especially allowing authorities to access personal data transferred from the EU to the U.S. for national security purposes) **does not grant data subjects actionable rights before the courts against the U.S. authorities and limits the protection of personal data required under EU law** 1. *"As a consequence of such a degree of interference with the fundamental rights of persons whose data are transferred to that third country, **the Court declared the Privacy Shield adequacy Decision invalid**.* " (EDPB, 2020)

- While the **Schrems II did not invalidate the use of SSCs, it did invalidate the Privacy Shield agreement**, in effect leaving each SSC vulnerable to a challenge that it not provide sufficient level of protection



Current issues: Data Transfers to the US (in the light of Schrems I and II cases)

Effectively, the judgement means that **data controllers now have to review their arrangements and possibly take additional measures to ensure that the protections required from the GDPR are met** without the overarching adequacy agreement for third-country data transfers or else risk sanction from data protection authorities. **Work is underway by the European Commission and European Data Protection Board** on more comprehensive guidance in relation to these additional measure measures. (source: information commissioners office, UK)

> *"The Court highlighted that it is the responsibility of the data exporter and the data importer to assess whether the level of protection required by EU law is respected in the third country concerned in order to determine if the guarantees provided by the SCCs or the BCRs can be complied with in practice. If this is not the case, you should assess whether you can provide supplementary measures to ensure an essentially equivalent level of protection as provided in the EEA, and if the law of the third country will not impinge on these supplementary measures so as to prevent their effectiveness."*

While **data controllers can still transfer personal data on the basis of SCCs in principle**, in practice, this will require an assessment to ensure that U.S. law does not impinge on the adequate level of protection and notify you must notify competent Supervisory Authority.

If such a review requires that appropriate safeguards would not be ensured, data controllers are required to suspend or end the transfers.

Privacy and Data Protection (I, II, III)

- The right to privacy – constitutional and statutory protections, privacy and the European Convention on Human Rights and EU Charter of Fundamental Rights
- Common law protection. Data Protection Regulation Scope, processing of personal data, legitimate bases, principles of data protection, sensitive data, issues of consent. Rights, supervision and enforcement.
- Data Protection in practice including international transfers, surveillance, cloud computing, and auditing. Current reform of the area.